itsdangerous cram sheet

If you only read one thing: tokens are signed, not encrypted. Anyone can base64-decode the payload, so never put secrets in it.

Legend: ★ most used · ⚠ gotcha

SIGN AND VERIFY ★

```
from itsdangerous import (
    URLSafeTimedSerializer)
s = URLSafeTimedSerializer(
    SECRET, salt="reset")
tok = s.dumps({"uid": 42})
s.loads(tok, max_age=3600)
# -> {'uid': 42}
```

`loads` returns data only if the signature checks out. `dumps` returns `str`.

PICK A CLASS

Class	Use for
`URLSafeTimedSerializer` ★	expiring URL tokens
`URLSafeSerializer`	URL tokens, no expiry
`TimedSerializer`	expiring, non-URL
`Serializer`	JSON + sig, no expiry
`Signer`	sign raw bytes
`TimestampSigner`	raw bytes + expiry

CATCH ERRORS

```
try:
    data = s.loads(
        tok, max_age=60)
except SignatureExpired:
    ...  # catch first
except BadSignature:
    ...  # tampered/key/salt
```

- All errors derive from `BadData`
- `BadPayload`: sig OK, decode failed. ⚠ not a `BadSignature`
- `e.payload`: the unverified bytes

SECRET KEY

- `python3 -c 'import os; print(os.urandom(16).hex())'`
- Load from env, never commit; changing it kills all tokens
- Rotate: pass `[old, new]` as the key: last signs, all verify

SALT

- One salt per purpose: `"activate"` ≠ `"upgrade"`
- Not secret, only distinct; same id + same salt = reusable token
- Defaults: serializer `itsdangerous`, signer `itsdangerous.Signer`

UPGRADE DIGEST, KEEP OLD TOKENS

```
URLSafeTimedSerializer(SECRET,
  signer_kwargs={
    "digest_method": sha512},
  fallback_signers=[{
    "digest_method": sha1}])
```

SHA-1 is the default and safe inside HMAC. SHA-512 makes longer tokens.

TIMESTAMPS

- `s.loads(tok, max_age=60, return_timestamp=True)` → `(data, datetime)`
- `e.date_signed` on expiry: aware UTC `datetime`
- `max_age` is in seconds

GOTCHAS

- ⚠ `max_age` on non-Timed serializers is silently ignored, because `loads` swallows `**kwargs`
- ⚠ Timed `loads` without `max_age` never expires
- ⚠ Future timestamp raises `SignatureExpired` (age < 0)
- ⚠ `Signer.unsign` returns bytes even for str input
- ⚠ `sep` in `[A-Za-z0-9-_=]` raises `ValueError`: it collides with base64
- ⚠ Sets, datetimes: `TypeError`; pass `serializer_kwargs={"default": ...}`
- ⚠ `loads_unsafe` skips verification; never with pickle

FIND IT IN THE REPO

- `src/itsdangerous/signer.py`: HMAC, key derivation
- `timed.py`: timestamps, expiry checks
- `serializer.py`: dumps/loads, fallbacks
- `url_safe.py`: compact JSON, zlib, base64
- `tests/test_itsdangerous/`: one file per module

DEV

Command	Does
`pip install -e . pytest freezegun`	test deps
`pytest -q`	297 tests, warnings = errors
`uv run --locked tox run -e typing`	mypy + pyright [unverified]